

SOC 2 Type 1 Report

Document ID	Version	Owner	Effective Date	Framework	Classification
SOC2-RPT-001	1.0	[Control Owner / Compliance Lead]	[Effective Date]	SOC 2	Confidential - Internal Use Only

Purpose

This SOC 2 Type 1 Report documents the design and readiness of [Organisation Name]’s controls as of [Report Date] for the in-scope system, services, people, processes, and technology supporting the delivery of [Service / Platform Name].

The purpose of this report is to:

- Assess whether the control environment is suitably designed to meet the applicable trust service commitments made to customers and stakeholders.
- Provide management with a point-in-time view of control readiness before, during, or after a formal SOC 2 Type 1 examination.
- Identify control design gaps, documentation weaknesses, implementation risks, and improvement actions.
- Support audit preparation, customer assurance activities, risk management, and governance oversight.
- Establish a baseline for future SOC 2 Type 2 operating effectiveness assessment.

This report focuses on control design at a specific point in time. It does not conclude whether controls operated effectively over a period of time.

Reporting Period & Scope

Reporting Basis

This is a point-in-time design assessment as of [Report Date]. Evidence was reviewed to determine whether controls were defined, assigned, documented, and capable of meeting the applicable service commitments and system requirements.

This report is intended to support SOC 2 Type 1 readiness and management reporting. If used in support of an external examination, the independent service auditor will make their own assessment and issue their own opinion.

In-Scope Trust Service Categories

The following trust service categories are included in scope:

Trust Service Category	In Scope	Scope Rationale
Security	Yes	Required for all SOC 2 assessments and applicable to the protection of systems, data, infrastructure, and services.
Availability	[Yes / No]	Applicable where [Organisation Name] makes uptime, resilience, continuity, or service availability commitments to customers.
Processing Integrity	[Yes / No]	Applicable where the service processes transactions, data, workflows, or outputs that must be complete, valid, accurate, timely, and authorised.

Trust Service Category	In Scope	Scope Rationale
Confidentiality	[Yes / No]	Applicable where the service stores, processes, or transmits confidential customer or business information.
Privacy	[Yes / No]	Applicable where the service collects, uses, retains, discloses, or disposes of personal information on behalf of customers or individuals.

In-Scope System

Component	Description
Service / Platform	[Service / Platform Name]
Business Function	[Primary business process supported by the system]
Production Environment	[Cloud provider / data centre / hosting model]
Application Components	[Applications, APIs, portals, databases, integrations]
Supporting Infrastructure	[Compute, storage, network, identity, logging, monitoring, backup components]
Data Types	[Customer data, confidential data, personal data, operational data, logs]
Users	[Internal users, administrators, customers, support staff, service accounts]
Locations	[Corporate offices, remote workforce locations, hosting regions]
Third-Party Providers	[Cloud provider, payment processor, support tool, monitoring platform, identity provider]

In-Scope Departments and Functions

Function	Included Activities
Executive Management	Governance, risk acceptance, policy approval, oversight.
Information Security	Security governance, control monitoring, risk management, incident response.
Engineering / Development	Secure development, change management, code review, deployment practices.
IT Operations / Infrastructure	Access administration, configuration management, monitoring, backup, availability.
Customer Support	Customer data handling, support access, ticket management, confidentiality practices.
Human Resources	Hiring, onboarding, training, background checks, termination processes.
Vendor Management	Third-party due diligence, contract review, vendor risk monitoring.
Legal / Compliance	Customer commitments, data protection requirements, contractual obligations.

Out-of-Scope Areas

The following areas are excluded from this report unless specifically stated elsewhere:

Area	Reason for Exclusion
[Legacy system name]	Not used to deliver the in-scope service.
[Development sandbox environment]	Does not process production customer data and is logically separated.
[Business unit / region]	Outside the current SOC 2 implementation scope.
Customer-managed environments	Operated and controlled by customers.
End-user customer controls	Dependent on customer configuration, user administration, and customer security practices.

Key Assumptions

This report is based on the following assumptions:

- Management has provided complete and accurate information regarding the in-scope system and control environment.
- Evidence supplied for review is current as of [Report Date].
- Control owners identified during the review have appropriate authority and accountability for their assigned controls.
- Relevant customer commitments, service descriptions, security statements, and contractual requirements have been made available for assessment.
- Third-party service provider responsibilities are understood and appropriately allocated between [Organisation Name], customers, and vendors.

Limitations

This report does not:

- Provide a legal opinion.
- Replace an independent SOC 2 auditor's report.
- Test control operating effectiveness over time.
- Validate every transaction, log entry, access event, or system configuration.
- Assess services, environments, or business processes excluded from scope.

Executive Summary

Overall Assessment

As of [Report Date], [Organisation Name] has established a foundational SOC 2 control environment for [Service / Platform Name]. The control framework is generally aligned to the selected trust service categories and includes defined policies, assigned control ownership, documented security practices, and technical safeguards across access control, change management, incident response, vendor management, and system monitoring.

The design of controls is assessed as:

Overall Design Readiness	Rating
SOC 2 Type 1 readiness	[Ready / Mostly Ready / Partially Ready / Not Ready]
Control design maturity	[Developing / Defined / Managed / Optimised]
Documentation completeness	[High / Medium / Low]
Evidence readiness	[High / Medium / Low]
Residual design risk	[Low / Medium / High]

Key Strengths

The review identified the following strengths:

- Formal information security policies are in place and approved by management.
- Access to production systems is restricted through role-based access and identity management controls.
- Multi-factor authentication is implemented for privileged and remote access.

- Code changes follow a documented workflow including review, approval, and controlled deployment.
- Security incidents are managed through an incident response process with defined escalation paths.
- Vendor risk management practices are in place for material service providers.
- Backups, monitoring, and alerting are defined for core production services.
- Employee onboarding and termination processes include access provisioning and deprovisioning steps.
- Security awareness training is assigned to employees.
- Customer commitments and service descriptions have been reviewed for alignment with control design.

Key Findings

The following key findings require management attention:

Finding ID	Finding Summary	Severity	Status
SOC2-T1-F01	Some control descriptions are not yet fully mapped to specific evidence sources and control owners.	Medium	Open
SOC2-T1-F02	Periodic user access reviews are defined but require stronger documentation of review criteria and evidence retention.	Medium	Open
SOC2-T1-F03	Vendor risk assessments are performed, but ongoing monitoring cadence is inconsistently documented.	Medium	Open
SOC2-T1-F04	Incident response roles are documented, but tabletop testing has not yet been completed for all relevant stakeholders.	Low	Open
SOC2-T1-F05	Security logging is enabled for key systems, but log review procedures require clearer alert triage expectations.	Medium	Open
SOC2-T1-F06	Business continuity and disaster recovery documentation require alignment with current recovery objectives.	Medium	Open

Management Conclusion

Management concludes that the SOC 2 Type 1 control environment is substantially designed but requires targeted remediation before an external Type 1 examination or before transitioning to Type 2 operating effectiveness monitoring.

Priority should be placed on:

- Finalising control ownership and evidence mapping.
- Strengthening access review documentation.
- Completing vendor monitoring procedures.
- Performing an incident response tabletop exercise.
- Aligning monitoring, backup, and continuity procedures with current service commitments.
- Establishing a repeatable evidence collection process for Type 2 readiness.

Methodology

Assessment Approach

The assessment was conducted using a structured SOC 2 readiness methodology focused on control design, documentation, ownership, and evidence availability.

The review included:

- Scope confirmation and system boundary review.
- Interviews with control owners and process stakeholders.
- Review of governance documents, policies, procedures, and technical standards.
- Evaluation of system architecture and data flow documentation.
- Assessment of control descriptions against management’s service commitments.
- Review of available control evidence.
- Identification of control design gaps and documentation gaps.
- Risk rating of findings.
- Development of recommended remediation actions.

Assessment Activities

Activity	Description	Participants
Scope Workshop	Confirmed trust service categories, system boundaries, data types, and relevant customer commitments.	Compliance, Security, Engineering, Operations, Legal
Control Walkthroughs	Reviewed how each key control is designed and who is responsible for execution.	Control Owners
Evidence Review	Inspected policies, screenshots, tickets, reports, logs, workflows, approvals, and system configurations.	Compliance, IT, Engineering
Risk Assessment	Evaluated control gaps based on likelihood, business impact, audit impact, and customer assurance impact.	Security, Compliance, Management
Findings Validation	Reviewed preliminary findings with responsible owners to confirm accuracy and feasibility of remediation.	Control Owners, Management
Management Review	Confirmed priorities, timelines, and action ownership.	Executive Sponsor, Compliance Lead

Evidence Reviewed

The following evidence types were reviewed where available:

Evidence Category	Examples Reviewed
Governance	Security policies, risk register, management meeting records, control ownership matrix.
Access Control	User access listings, identity provider settings, privileged access records, access review evidence.
Human Resources	Onboarding checklists, training records, termination procedures, role change process documentation.

Evidence Category	Examples Reviewed
Change Management	Pull requests, code review records, deployment tickets, approval workflows, release documentation.
Incident Response	Incident response plan, incident ticket examples, escalation procedures, communications templates.
Vendor Management	Vendor inventory, risk assessments, contracts, security questionnaires, vendor assurance reports.
System Operations	Monitoring dashboards, alert configuration, backup schedules, job results, capacity monitoring.
Security Monitoring	Logging configuration, alert rules, vulnerability scans, endpoint protection status, remediation records.
Business Continuity	Continuity plans, disaster recovery procedures, backup restore documentation, recovery objectives.
Data Protection	Encryption settings, data classification records, retention schedules, secure disposal procedures.

Rating Methodology

Findings were rated using the following severity model:

Severity	Definition	Typical Management Response
High	A significant design gap that may prevent the control environment from meeting a key service commitment or creates material audit, customer, security, or operational risk.	Immediate remediation required before external examination or customer reliance.
Medium	A control is partially designed, inconsistently documented, or dependent on informal practices. The issue may affect audit readiness or reduce confidence in control reliability.	Remediation should be completed within an agreed short-term timeframe.
Low	A minor documentation, consistency, or enhancement issue that does not materially impair the control design but should be addressed to improve maturity.	Address through normal improvement planning.
Observation	An improvement opportunity with no current control deficiency identified.	Consider for maturity enhancement.

Design Assessment Criteria

A control was considered suitably designed when:

- The control objective was clearly understood.
- The control owner was identified.
- The control activity was documented.
- The control addressed a relevant risk or service commitment.
- The control could reasonably prevent, detect, or correct the related risk.
- The control frequency was appropriate.
- Evidence of performance could be retained.
- Roles and responsibilities were sufficiently defined.
- Dependencies on third parties or customers were understood.
- The control was aligned with current system architecture and operating practices.

Detailed Findings / Results (with structure)

1. Governance and Risk Management

Summary

Governance structures are established, including management oversight, security policy ownership, and risk management responsibilities. Policies exist for key security domains; however, some control ownership and evidence mapping requires further refinement.

Control Area	Design Status	Result
Security governance	Designed	Satisfactory
Policy management	Designed with improvement needed	Minor gap
Risk assessment	Designed with improvement needed	Minor gap
Control ownership	Partially designed	Finding raised
Management oversight	Designed	Satisfactory

Positive Results

- Executive sponsorship has been assigned for SOC 2 implementation.
- Information security policies are approved and available to employees.
- Risk assessment activities are performed and documented in a risk register.
- Security responsibilities are assigned across Security, IT, Engineering, HR, and Legal.
- Management receives updates on security and compliance initiatives.

Finding SOC2-T1-F01 - Control Ownership and Evidence Mapping Require Completion

Attribute	Detail
Severity	Medium
Status	Open
Owner	[Compliance Lead]
Target Date	[Target Date]
Affected Area	SOC 2 control management
Risk	Controls may be inconsistently performed or difficult to evidence during an external examination.

Condition: Some controls have been identified but are not yet fully documented with assigned owners, performance frequency, evidence source, retention location, and review expectations.

Impact: Incomplete control documentation may delay audit readiness, create ambiguity during evidence collection, and reduce management’s ability to monitor control performance.

Recommended Action: Complete the SOC 2 control matrix with clear ownership, control descriptions, control frequency, evidence requirements, evidence location, and reviewer responsibilities.

2. Access Control and Identity Management

Summary

Access control practices are generally well designed. Identity management is centralised through [Identity Provider], and privileged access is restricted. Multi-factor authentication is implemented for administrative and remote access. Periodic access reviews are defined but need stronger evidence requirements and review criteria.

Control Area	Design Status	Result
User provisioning	Designed	Satisfactory
User termination	Designed	Satisfactory
Privileged access	Designed	Satisfactory
Multi-factor authentication	Designed	Satisfactory
Access reviews	Partially designed	Finding raised
Service accounts	Designed with improvement needed	Minor gap

Positive Results

- New access requests require approval before provisioning.
- Access is based on role and business need.
- Privileged access is limited to authorised personnel.
- Termination procedures include removal of access from key systems.
- Multi-factor authentication is enforced for administrative accounts.
- Access to production systems is limited to approved personnel.

Finding SOC2-T1-F02 - Access Review Evidence Requirements Require Strengthening

Attribute	Detail
Severity	Medium
Status	Open
Owner	[IT Operations Lead]
Target Date	[Target Date]
Affected Area	Periodic access review
Risk	Inappropriate access may remain undetected or access reviews may not be auditable.

Condition: Periodic access reviews are planned, but the procedure does not fully define review scope, required evidence, approval standards, exception handling, or documentation of remediation.

Impact: Access reviews may be performed inconsistently, making it difficult to demonstrate that user and privileged access remains appropriate.

Recommended Action: Update the access review procedure to define review frequency, systems in scope, reviewer responsibilities, required evidence, criteria for approval, escalation of exceptions, remediation timelines, and evidence retention.

3. Human Resources Security

Summary

Human resources security controls are suitably designed for onboarding, employee acknowledgement of policies, security awareness training, and termination coordination. Background screening and role-based onboarding requirements should be confirmed for all applicable roles.

Control Area	Design Status	Result
Hiring controls	Designed	Satisfactory
Background screening	Designed with improvement needed	Observation
Security awareness training	Designed	Satisfactory
Policy acknowledgement	Designed	Satisfactory
Termination coordination	Designed	Satisfactory

Positive Results

- New employees complete onboarding activities before receiving production access.
- Employees are required to acknowledge relevant policies.
- Security awareness training is assigned and tracked.
- Terminations trigger access removal through HR and IT workflows.
- Managers are responsible for confirming role-based access needs.

Observation SOC2-T1-O01 - Background Screening Applicability Should Be Documented

Attribute	Detail
Severity	Observation
Status	Open
Owner	[HR Lead]
Target Date	[Target Date]
Affected Area	Hiring and onboarding
Risk	Screening expectations may be inconsistently applied across roles or regions.

Recommended Action: Document which roles require background screening, the timing of screening, permissible regional variations, exception handling, and evidence retention requirements.

4. Change Management and Secure Development

Summary

Change management controls are suitably designed for the in-scope service. Code changes are tracked, reviewed, approved, and deployed through controlled workflows. Segregation between development and production access is defined. Additional clarity should be maintained for emergency changes.

Control Area	Design Status	Result
Code review	Designed	Satisfactory
Change approval	Designed	Satisfactory
Deployment controls	Designed	Satisfactory
Emergency changes	Designed with improvement needed	Observation
Separation of environments	Designed	Satisfactory
Secure development practices	Designed	Satisfactory

Positive Results

- Source code is maintained in [Repository Platform].

- Changes require peer review before merge.
- Deployment pipelines include controlled permissions.
- Production deployments are limited to authorised personnel or automated workflows.
- Development, test, and production environments are logically separated.
- Security considerations are included in development practices.

Observation SOC2-T1-O02 - Emergency Change Documentation Should Be Formalised

Attribute	Detail
Severity	Observation
Status	Open
Owner	[Engineering Lead]
Target Date	[Target Date]
Affected Area	Emergency change management
Risk	Emergency changes may not be consistently reviewed after implementation.

Recommended Action: Document the emergency change process, including criteria for emergency classification, required approval, retrospective review, testing expectations, and evidence retention.

5. System Operations, Monitoring, and Availability

Summary

Operational controls are in place for monitoring, alerting, backups, and service availability. The monitoring design covers key production systems, although triage responsibilities and alert review expectations require clarification. Backup processes are documented, but recovery objectives should be aligned with service commitments.

Control Area	Design Status	Result
Infrastructure monitoring	Designed	Satisfactory
Alert management	Partially designed	Finding raised
Backup scheduling	Designed	Satisfactory
Backup restoration	Designed with improvement needed	Minor gap
Capacity monitoring	Designed	Satisfactory
Availability commitments	Designed with improvement needed	Minor gap

Positive Results

- Production systems are monitored using [Monitoring Tool].
- Alerts are configured for critical infrastructure and service health events.
- Backup jobs are scheduled for key data stores.
- Operational teams receive incident and service alerts.
- System status and uptime are monitored against internal expectations.

Finding SOC2-T1-F05 - Alert Triage and Log Review Expectations Require Clarification

Attribute	Detail
Severity	Medium
Status	Open
Owner	[Security Operations Lead]
Target Date	[Target Date]
Affected Area	Monitoring and alert management
Risk	Security or operational alerts may not be consistently reviewed, escalated, or documented.

Condition: Logging and alerting are enabled for key systems; however, the documented process does not fully define alert severity, triage ownership, expected response times, escalation criteria, and evidence of review.

Impact: Important security or availability events may not be identified and addressed consistently. Audit evidence may not clearly demonstrate that alerts are monitored and acted upon.

Recommended Action: Create or update the monitoring and alert response procedure to define alert categories, review responsibilities, escalation paths, ticketing requirements, evidence expectations, and periodic review of alert effectiveness.

6. Incident Response

Summary

An incident response plan is in place and includes identification, escalation, containment, investigation, communication, and closure activities. Roles are documented, but a formal tabletop exercise has not yet been completed across all required stakeholders.

Control Area	Design Status	Result
Incident response plan	Designed	Satisfactory
Escalation process	Designed	Satisfactory
Incident classification	Designed	Satisfactory
Communication procedures	Designed	Satisfactory
Tabletop testing	Partially designed	Finding raised
Lessons learned	Designed with improvement needed	Minor gap

Positive Results

- Incident response roles and responsibilities are documented.
- Security events can be escalated through defined channels.
- Incident handling stages are defined.
- Customer and legal notification considerations are included.
- Incident records are retained in [Ticketing / Case Management Tool].

Finding SOC2-T1-F04 - Incident Response Tabletop Exercise Not Yet Completed

Attribute	Detail
Severity	Low
Status	Open
Owner	[Security Lead]

Attribute	Detail
Target Date	[Target Date]
Affected Area	Incident response readiness
Risk	Incident response participants may not be fully prepared to execute assigned responsibilities during a real event.

Condition: The incident response plan is documented, but a recent tabletop exercise involving key stakeholders has not yet been completed.

Impact: Unvalidated response procedures may result in delays, unclear decision-making, or inconsistent communications during an incident.

Recommended Action: Conduct a tabletop exercise covering a realistic security incident scenario. Document attendance, scenario details, decisions made, gaps identified, lessons learned, and improvement actions.

7. Vendor and Third-Party Risk Management

Summary

Vendor management controls are designed for identifying material vendors, assessing risk, and reviewing vendor assurance information. The vendor inventory is maintained, and critical vendors are identified. Ongoing monitoring requirements should be more clearly defined.

Control Area	Design Status	Result
Vendor inventory	Designed	Satisfactory
Vendor risk classification	Designed	Satisfactory
Due diligence	Designed	Satisfactory
Contractual security terms	Designed with improvement needed	Minor gap
Ongoing monitoring	Partially designed	Finding raised
Vendor offboarding	Designed with improvement needed	Observation

Positive Results

- Material service providers are documented in a vendor inventory.
- Vendor risk is considered during onboarding.
- Security questionnaires and assurance reports are requested for key vendors.
- Contracts include confidentiality and service expectations where applicable.
- Vendor ownership is assigned to business stakeholders.

Finding SOC2-T1-F03 - Vendor Ongoing Monitoring Cadence Is Inconsistently Documented

Attribute	Detail
Severity	Medium
Status	Open
Owner	[Vendor Management Owner]
Target Date	[Target Date]
Affected Area	Vendor risk management
Risk	Material vendor risks may not be reassessed as vendor services, assurance reports, or risk conditions change.

Condition: Vendor due diligence is performed during onboarding; however, the process does not consistently define ongoing monitoring frequency, evidence requirements, reassessment triggers, or responsible reviewers.

Impact: Changes in vendor risk posture may not be identified in a timely manner, potentially affecting customer commitments, service availability, confidentiality, and security.

Recommended Action: Update the vendor management procedure to define monitoring frequency by vendor risk tier, required annual evidence, review of vendor assurance reports, reassessment triggers, exception tracking, and management escalation.

8. Data Protection and Confidentiality

Summary

Data protection controls are designed to protect confidential and customer data. Encryption, access restrictions, data handling expectations, and retention practices are defined. Further maturity can be gained by improving data classification coverage and disposal evidence.

Control Area	Design Status	Result
Data classification	Designed with improvement needed	Observation
Encryption in transit	Designed	Satisfactory
Encryption at rest	Designed	Satisfactory
Confidentiality obligations	Designed	Satisfactory
Data retention	Designed with improvement needed	Observation
Secure disposal	Designed with improvement needed	Observation

Positive Results

- Customer data is protected using logical access controls.
- Encryption is implemented for data in transit.
- Encryption is implemented for key data stores at rest.
- Employees are subject to confidentiality obligations.
- Customer data handling expectations are documented.
- Access to confidential information is limited based on role.

Observation SOC2-T1-O03 - Data Classification and Retention Evidence Should Be Strengthened

Attribute	Detail
Severity	Observation
Status	Open
Owner	[Data Governance Owner]
Target Date	[Target Date]
Affected Area	Data protection
Risk	Data handling, retention, and disposal requirements may be inconsistently applied.

Recommended Action: Maintain a data classification register for in-scope data types and document retention and disposal expectations for customer data, logs, backups, and operational records.

9. Privacy

Summary

Where privacy is included in scope, privacy governance controls are designed to support notice, consent where applicable, data subject rights, purpose limitation, retention, and secure handling of personal information. Privacy-specific evidence should be maintained for data flows and subprocessors.

Control Area	Design Status	Result
Privacy notice	[Designed / Not applicable]	[Result]
Personal data inventory	[Designed with improvement needed / Not applicable]	[Result]
Data subject request process	[Designed / Not applicable]	[Result]
Subprocessor disclosure	[Designed with improvement needed / Not applicable]	[Result]
Privacy incident coordination	[Designed / Not applicable]	[Result]

Positive Results

- Privacy responsibilities are assigned to [Privacy Owner / Legal].
- Personal information handled by the in-scope service is identified.
- Privacy commitments are reflected in customer-facing documentation.
- Data subject or customer request processes are defined where applicable.
- Privacy incidents are coordinated with security incident response procedures.

Observation SOC2-T1-O04 - Personal Data Flow Documentation Should Be Maintained

Attribute	Detail
Severity	Observation
Status	Open
Owner	[Privacy Owner]
Target Date	[Target Date]
Affected Area	Privacy governance
Risk	Privacy commitments and operational practices may become misaligned as systems or subprocessors change.

Recommended Action: Maintain current personal data flow documentation, including data sources, purposes, storage locations, transfer points, subprocessors, retention requirements, and deletion processes.

10. Business Continuity and Disaster Recovery

Summary

Business continuity and disaster recovery documentation exists but requires alignment with current system architecture, backup capabilities, recovery objectives, and customer commitments. Recovery responsibilities should be validated through testing.

Control Area	Design Status	Result
Business continuity plan	Designed with improvement needed	Minor gap

Control Area	Design Status	Result
Disaster recovery plan	Partially designed	Finding raised
Recovery objectives	Partially designed	Finding raised
Backup restoration testing	Designed with improvement needed	Minor gap
Crisis communications	Designed with improvement needed	Observation

Positive Results

- Backup schedules are defined for critical systems.
- Business continuity responsibilities are assigned.
- Recovery considerations are included in operational planning.
- Critical vendors and infrastructure dependencies are understood.

Finding SOC2-T1-F06 - Recovery Documentation Requires Alignment with Current Service Commitments

Attribute	Detail
Severity	Medium
Status	Open
Owner	[Operations Lead]
Target Date	[Target Date]
Affected Area	Business continuity and disaster recovery
Risk	Recovery plans may not support stated customer commitments or operational expectations.

Condition: Continuity and recovery documentation exists but does not fully reflect current system architecture, critical dependencies, recovery priorities, recovery time expectations, recovery point expectations, or testing evidence.

Impact: During a disruption, recovery activities may be delayed or inconsistent. Customers may rely on service availability commitments that are not fully supported by documented recovery plans.

Recommended Action: Update business continuity and disaster recovery documentation to align with the current production environment, critical dependencies, customer commitments, backup capabilities, recovery objectives, communication procedures, and test schedule.

Findings Summary

Finding ID	Category	Severity	Owner	Target Date	Status
SOC2-T1-F01	Governance and Risk Management	Medium	[Compliance Lead]	[Target Date]	Open
SOC2-T1-F02	Access Control and Identity Management	Medium	[IT Operations Lead]	[Target Date]	Open
SOC2-T1-F03	Vendor and Third-Party Risk Management	Medium	[Vendor Management Owner]	[Target Date]	Open
SOC2-T1-F04	Incident Response	Low	[Security Lead]	[Target Date]	Open
SOC2-T1-F05	System Operations, Monitoring, and Availability	Medium	[Security Operations Lead]	[Target Date]	Open
SOC2-T1-F06	Business Continuity and Disaster Recovery	Medium	[Operations Lead]	[Target Date]	Open

Observations Summary

Observation ID	Category	Owner	Target Date	Status
SOC2-T1-O01	Human Resources Security	[HR Lead]	[Target Date]	Open
SOC2-T1-O02	Change Management and Secure Development	[Engineering Lead]	[Target Date]	Open
SOC2-T1-O03	Data Protection and Confidentiality	[Data Governance Owner]	[Target Date]	Open
SOC2-T1-O04	Privacy	[Privacy Owner]	[Target Date]	Open

Analysis

Control Design Maturity

The control environment demonstrates a defined and maturing approach to SOC 2 readiness. Core security controls are present, and the organisation has established accountability for most high-risk areas. The strongest areas are access restriction, change management, security governance, and incident response planning.

The principal design weaknesses relate to documentation completeness, control evidence definition, and repeatability. These gaps are common during Type 1 readiness activities but should be resolved before relying on the control environment for Type 2 operating effectiveness.

Domain	Maturity Assessment	Commentary
Governance	Defined	Policies and management oversight exist; control mapping should be finalised.
Access Control	Defined	Core access controls are present; review evidence needs refinement.
HR Security	Defined	Onboarding and termination controls are documented and practical.
Change Management	Defined	Development and deployment workflows support controlled change.
Monitoring	Developing	Tools are in place; triage and review procedures require more detail.
Incident Response	Defined	Plan exists; tabletop validation is needed.
Vendor Management	Developing	Onboarding due diligence is present; ongoing monitoring should be formalised.
Data Protection	Defined	Encryption and confidentiality controls exist; classification evidence can improve.
Availability	Developing	Monitoring and backup controls exist; continuity documentation should be aligned.
Privacy	[Developing / Defined / Not applicable]	Privacy scope should be supported by current data flow documentation where applicable.

Readiness for SOC 2 Type 1 Examination

[Organisation Name] is [ready / mostly ready / partially ready / not ready] to proceed with a SOC 2 Type 1 examination based on the current design of controls.

Proceeding with an external Type 1 examination is recommended only after management has:

- Confirmed final scope and trust service categories.
- Approved the system description.
- Completed control owner assignments.
- Finalised the control matrix.
- Remediated medium-severity findings or documented accepted risk.

- Confirmed that control evidence is available for the report date.
- Validated that policies and procedures reflect actual practices.
- Confirmed that customer commitments are accurately represented.

Readiness for SOC 2 Type 2 Transition

To transition successfully from Type 1 to Type 2, [Organisation Name] should establish a repeatable control operation and evidence collection cadence. The organisation should treat the Type 1 report date as the baseline for continuous control performance.

Key Type 2 readiness needs include:

- Maintaining evidence throughout the observation period.
- Performing periodic access reviews according to the defined schedule.
- Tracking changes with complete approval, review, and deployment evidence.
- Recording security incidents and documenting resolution activities.
- Performing vendor reviews based on vendor risk tier.
- Retaining monitoring, alert, backup, and recovery evidence.
- Tracking employee training completion and policy acknowledgements.
- Maintaining risk assessment updates and management review records.
- Reviewing exceptions and documenting remediation.
- Monitoring control performance through management reporting.

Risk Analysis

The identified findings do not indicate a complete absence of foundational controls. However, if not remediated, they may create audit challenges and reduce confidence in the organisation's ability to demonstrate consistent control operation.

Risk Theme	Current Risk Level	Analysis
Audit readiness	Medium	Documentation and evidence mapping gaps may delay or complicate examination activities.
Access appropriateness	Medium	Access controls are designed, but review procedures need clearer evidence and criteria.
Vendor dependency	Medium	Vendor onboarding is controlled, but ongoing monitoring requires consistency.
Incident preparedness	Low to Medium	Incident response procedures exist but have not been fully validated through exercise.
Operational monitoring	Medium	Alerts exist, but triage and review expectations require formalisation.
Availability resilience	Medium	Backup and recovery practices require clearer alignment with service commitments.
Data protection	Low to Medium	Core protections are present; classification and retention documentation should mature.

Root Cause Themes

The findings appear to be driven by the following root cause themes:

- Rapid growth of systems and processes ahead of formal compliance documentation.
- Control activities performed in practice but not consistently described in audit-ready language.
- Evidence retained across multiple tools without a central evidence strategy.
- Informal ownership for some cross-functional controls.
- Need to mature from implementation-focused activity to repeatable compliance operations.
- Limited prior SOC 2 evidence collection experience.

Management Prioritisation

Management should prioritise findings based on audit impact, customer assurance impact, and security risk.

Priority	Action Theme	Related Findings
1	Finalise control matrix, ownership, evidence sources, and control descriptions.	SOC2-T1-F01
2	Strengthen access review procedure and evidence requirements.	SOC2-T1-F02
3	Clarify monitoring, alert triage, and log review expectations.	SOC2-T1-F05
4	Align disaster recovery documentation with current commitments.	SOC2-T1-F06
5	Formalise vendor ongoing monitoring cadence.	SOC2-T1-F03
6	Conduct incident response tabletop exercise.	SOC2-T1-F04

Recommendations & Actions

Remediation Plan

Action ID	Related Finding	Action	Owner	Target Date	Success Criteria	Status
ACT-001	SOC2-T1-F01	Complete SOC 2 control matrix with owners, frequency, evidence, systems, and reviewer requirements.	[Compliance Lead]	[Target Date]	Approved control matrix available and reviewed by management.	Open
ACT-002	SOC2-T1-F01	Establish central evidence repository with folder structure aligned to control areas.	[Compliance Lead]	[Target Date]	Evidence repository created with access restricted to authorised personnel.	Open
ACT-003	SOC2-T1-F02	Update access review procedure and templates.	[IT Operations Lead]	[Target Date]	Procedure defines scope, review criteria, exception handling, approval, and retention.	Open
ACT-004	SOC2-T1-F02	Perform pilot access review for in-scope production systems.	[IT Operations Lead]	[Target Date]	Review completed, exceptions tracked, remediation evidence retained.	Open
ACT-005	SOC2-T1-F03	Update vendor risk management procedure to include ongoing monitoring by risk tier.	[Vendor Management Owner]	[Target Date]	Procedure approved and vendor inventory updated with review dates.	Open

Action ID	Related Finding	Action	Owner	Target Date	Success Criteria	Status
ACT-006	SOC2-T1-F03	Complete reassessment for critical vendors.	[Vendor Management Owner]	[Target Date]	Current assurance evidence or documented risk acceptance retained for each critical vendor.	Open
ACT-007	SOC2-T1-F04	Conduct incident response tabletop exercise.	[Security Lead]	[Target Date]	Exercise record includes scenario, attendees, outcomes, issues, and action items.	Open
ACT-008	SOC2-T1-F05	Document alert triage and log review procedure.	[Security Operations Lead]	[Target Date]	Procedure defines severity, ownership, response expectations, and evidence requirements.	Open
ACT-009	SOC2-T1-F05	Validate monitoring coverage for critical production systems.	[Security Operations Lead]	[Target Date]	Monitoring inventory confirms coverage and alert routing for critical assets.	Open
ACT-010	SOC2-T1-F06	Update business continuity and disaster recovery documentation.	[Operations Lead]	[Target Date]	Plans reflect current architecture, dependencies, recovery objectives, and communication roles.	Open
ACT-011	SOC2-T1-F06	Complete backup restoration or recovery validation exercise.	[Operations Lead]	[Target Date]	Test evidence demonstrates recovery capability and records any issues.	Open
ACT-012	Observations	Address improvement observations through control maturity backlog.	[Compliance Lead]	[Target Date]	Observations tracked, prioritised, and assigned.	Open

Recommended Timeline

Phase	Target Completion	Activities
Phase 1 - Scope and Control Finalisation	[Date]	Confirm scope, finalise trust service categories, approve system description, complete control matrix.
Phase 2 - Documentation Remediation	[Date]	Update access review, vendor monitoring, monitoring, continuity, and emergency change procedures.
Phase 3 - Evidence Readiness	[Date]	Establish evidence repository, collect point-in-time evidence, validate evidence completeness.
Phase 4 - Validation Activities	[Date]	Conduct tabletop exercise, pilot access review, vendor reassessment, backup restoration test.
Phase 5 - Management Readiness Review	[Date]	Review open risks, approve residual risk, confirm readiness for external Type 1 examination.
Phase 6 - Type 2 Preparation	[Date]	Establish recurring control calendar, evidence cadence, exception tracking, and management reporting.

Control Calendar for Type 2 Readiness

Control Activity	Recommended Frequency	Owner	Evidence
Management review of security and compliance status	Quarterly	[Executive Sponsor / Compliance Lead]	Meeting minutes, dashboard, action tracker.

Control Activity	Recommended Frequency	Owner	Evidence
Risk register review	Quarterly	[Security Lead]	Updated risk register, approvals, remediation status.
User access review	Quarterly or semi-annually based on risk	[IT Operations Lead]	User listing, reviewer sign-off, exceptions, remediation evidence.
Privileged access review	Quarterly	[IT Operations Lead]	Admin user listing, approvals, removal evidence.
Vendor review for critical vendors	Annually or upon material change	[Vendor Management Owner]	Vendor assessment, assurance report review, risk decision.
Security awareness training	At hire and annually	[HR Lead]	Completion report, reminders, exception tracking.
Vulnerability review	Monthly or according to risk	[Security Lead]	Scan results, remediation tickets, risk acceptance.
Incident response tabletop	Annually	[Security Lead]	Scenario, attendance, lessons learned, action plan.
Backup restoration test	At least annually	[Operations Lead]	Test record, results, remediation items.
Business continuity review	Annually or upon material change	[Operations Lead]	Updated plan, approval, test results.
Policy review	Annually	[Compliance Lead]	Approved policy versions, change history.
Change management sampling	Monthly or quarterly	[Engineering Lead]	Sampled changes, approvals, review evidence.

Management Action Requirements

Management is responsible for ensuring that:

- Remediation owners have sufficient authority and resources.
- Target dates are realistic and tracked to completion.
- Risk acceptances are documented, justified, time-bound, and approved.
- Updated procedures are communicated to affected personnel.
- Evidence is retained in a consistent and access-controlled location.
- Open findings are reviewed regularly until closed.
- Closure evidence is independently reviewed by Compliance or Internal Audit where feasible.
- External auditor expectations are confirmed before examination fieldwork.

Criteria for Finding Closure

A finding may be closed when:

- The corrective action has been completed.
- Updated documentation has been approved.
- Control ownership is assigned.
- Required evidence has been retained.
- Any affected stakeholders have been informed or trained.
- The control has been validated through walkthrough, sample evidence, or management review.

- Residual risk is acceptable to management.

Residual Risk Acceptance

If management elects not to remediate a finding before the SOC 2 Type 1 examination, a risk acceptance record should be completed and approved.

Required Field	Description
Finding ID	The finding being accepted.
Risk Description	Summary of the risk and affected service commitments.
Business Rationale	Reason remediation is deferred or not pursued.
Compensating Controls	Existing controls that reduce the risk.
Acceptance Period	Defined period for which risk is accepted.
Approver	Authorised management approver.
Review Date	Date risk acceptance must be reviewed.

Distribution & Confidentiality

Distribution

This report is confidential and intended only for authorised recipients with a legitimate business need. Distribution must be approved by [Report Owner / Compliance Lead].

Authorised recipients may include:

Recipient Group	Access Level	Purpose
Executive Management	Full report	Governance oversight and risk decision-making.
Compliance and Security Teams	Full report	Remediation tracking and audit preparation.
Control Owners	Relevant sections	Action planning and control improvement.
Legal	Full or relevant sections	Review of customer commitments and confidentiality obligations.
External SOC 2 Auditor	Full report, if approved	Audit planning and readiness review.
Customers or Prospects	Not distributed unless approved	Customer assurance requests should be handled through approved external materials.
Third Parties	Not distributed unless approved	Distribution requires confidentiality protections and business justification.

Confidentiality Requirements

This report contains sensitive information regarding [Organisation Name]’s control environment, system architecture, operational practices, security processes, vendors, and remediation plans.

Recipients must:

- Protect the report from unauthorised access, disclosure, copying, or distribution.
- Store the report only in approved repositories.
- Avoid forwarding the report outside authorised distribution channels.
- Use the report only for approved governance, compliance, audit, or remediation purposes.
- Redact sensitive technical details before any approved external sharing.
- Notify [Compliance Lead / Legal Contact] immediately if the report is disclosed in error.

External Sharing

This internal readiness report should not be provided to customers, prospects, vendors, or other external parties unless approved by [Legal / Compliance / Executive Sponsor].

Where external assurance is required, [Organisation Name] should provide one of the following approved materials instead:

- Final independent SOC 2 report, when available.
- Customer assurance letter.
- Security overview or whitepaper.
- Completed security questionnaire.
- Approved bridge letter, if applicable.
- Approved executive summary with sensitive findings removed.

Record Retention

Record	Retention Requirement	Storage Location
Final SOC 2 Type 1 Report	[Retention Period]	[Approved Repository]
Evidence reviewed	[Retention Period]	[Evidence Repository]
Findings and remediation tracker	[Retention Period]	[GRC Tool / Repository]
Management approvals	[Retention Period]	[Approval System / Repository]
Risk acceptance records	[Retention Period]	[Risk Register / Repository]
Auditor communications	[Retention Period]	[Compliance Repository]

Report Approval

Role	Name	Approval Date	Signature / Approval Record
Executive Sponsor	[Name]	[Date]	[Approval Record]
Report Owner	[Name]	[Date]	[Approval Record]
Security Lead	[Name]	[Date]	[Approval Record]
Compliance Lead	[Name]	[Date]	[Approval Record]
Legal Reviewer	[Name]	[Date]	[Approval Record]